

TP : Scans de Vulnérabilités et Détection d'Anomalies (Windows & Linux)

Objectifs opérationnels

1. Cartographier rapidement les services distants et relever les bannières non masquées.
2. Détecter les failles critiques immédiatement accessibles via le moteur Nmap NSE.
3. Configurer les environnements Linux et Windows pour autoriser un scan d'audit authentifié.
4. Lancer un scan automatisé complet (OpenVAS / GVM ou Nessus) et analyser les scores CVSS obtenus.
5. Détecter et justifier au moins un faux positif lié au mécanisme de rétroportage (*backporting*).
6. Appliquer une première mesure de réduction de surface d'attaque pour valider la disparition d'une faille.

Topologie et Adressage du Lab

Avant de débuter, relevez les adresses IP de vos trois machines virtuelles et notez-les :

- **Machine d'Audit** : IP_AUDIT = _____
- **Cible Linux** : IP_LINUX = _____
- **Cible Windows** : IP_WIN = _____

Partie 1 : Cartographie Rapide et Bannières Réseau

Depuis le terminal de votre **machine d'audit**, vous allez commencer par identifier les services visibles depuis le réseau extérieur sans aucun droit d'accès.

1.1 Inspection des bannières logicielles (*Banner Grabbing*)

1. Interrogez les bannières des services d'administration et de navigation sur la machine Linux :
nc -vn <IP_LINUX> 22
curl -k -I http://<IP_LINUX>
 2. Interrogez le certificat et la négociation TLS sur la machine Windows ou Linux si un port HTTPS est ouvert :
openssl s_client -connect <IP_WIN>:443 -brief
- **Questions à consigner :**
 - Le numéro de version exact de l'application apparaît-il en clair dans la bannière ?
 - Pourquoi la divulgation de cette version représente-t-elle un gain de temps majeur

pour un attaquant ?

1.2 Détection active via Nmap et les scripts NSE

1. Lancez un scan TCP complet avec détection de version et d'OS sur vos deux cibles :

Scan de la cible Linux

```
nmap -sS -sV -O -T4 -p- <IP_LINUX>
```

Scan de la cible Windows

```
nmap -sS -sV -O -T4 -p- <IP_WIN>
```

2. Exécutez la catégorie de scripts vuln de Nmap contre la machine Linux pour repérer d'éventuelles failles connues :

```
nmap -sV --script vuln -p 22,80,443 <IP_LINUX>
```

3. Interrogez spécifiquement les vulnérabilités SMB et de partage sur la machine Windows Server :

```
nmap -p 445 --script smb-vuln* <IP_WIN>
```

- **Questions à consigner :**

- Quels services sont identifiés comme vulnérables par Nmap ?
- Y a-t-il des alertes SMB (MS17-010, fuites d'informations, dialectes SMB obsolètes) sur Windows ?

Partie 2 : Préparation des Systèmes pour l'Audit Authentifié

Un scan réseau externe ne voit que la "façade". Pour permettre au scanner d'inspecter les correctifs internes, les clés de registre et les fichiers de configuration, vous devez configurer un accès d'audit dédié.

2.1 Configuration de la cible Linux

Connectez-vous sur votre **machine Linux** (via SSH ou console Guacamole) :

1. Créez un compte de service réservé à l'audit :

```
sudo useradd -m -s /bin/bash auditscan
```

```
sudo passwd auditscan
```

(Définissez un mot de passe robuste, ex : *AuditSecurite2026!*)

2. Autorisez ce compte à exécuter des commandes sudo d'inspection sans redemander le mot de passe :

```
echo "auditscan ALL=(ALL) NOPASSWD: ALL" | sudo tee /etc/sudoers.d/auditscan
```

```
sudo chmod 440 /etc/sudoers.d/auditscan
```

3. Validez le bon fonctionnement depuis la **machine d'audit** :
`ssh auditscan@<IP_LINUX> "sudo uname -a && sudo id"`

(La commande doit retourner uid=0(root) sans blocage ni demande de mot de passe supplémentaire).

2.2 Configuration de la cible Windows Server

Connectez-vous sur votre **machine Windows Server** en session Administrateur :

1. Ouvrez une console **PowerShell en tant qu'Administrateur** et activez la gestion à distance (WinRM) :
`Enable-PSRemoting -Force`
`Set-Service -Name WinRM -StartupType Automatic`
`Start-Service -Name WinRM`
2. Vérifiez que les règles du pare-feu local autorisent bien les flux d'administration :
`Get-NetFirewallRule -DisplayGroup "Gestion à distance de Windows" | Select-Object DisplayName, Enabled, Direction`
3. Depuis votre **machine d'audit** (ou poste d'administration), testez la connectivité sur les ports SMB (445) et WinRM (5985) :
`nc -zv <IP_WIN> 445`
`nc -zv <IP_WIN> 5985`

Partie 3 : Déploiement et Exécution du Scan de Vulnérabilités

Vous allez maintenant utiliser un scanner d'audit professionnel (**OpenVAS / GVM** ou **Nessus Essentials** selon l'outil déployé sur votre lab).

3.1 Démarrage et accès à la plateforme

1. Sur la **machine d'audit**, vérifiez que les services du scanner sont actifs :
 - **Pour OpenVAS / Greenbone :**
`sudo gvm-check-setup`
`sudo gvm-start`

Accès Web : `https://127.0.0.1:9392` ou `https://<IP_AUDIT>:9392`
 - **Pour Nessus :**
`sudo systemctl status nessusd`
Si inactif :
`sudo systemctl start nessusd`

Accès Web : <https://127.0.0.1:8834> ou https://<IP_AUDIT>:8834

2. Connectez-vous à l'interface d'administration avec les identifiants fournis par votre formateur.

3.2 Création des cibles et configuration des identifiants (*Credentials*)

1. **Création des identifiants dans le scanner :**
 - *Identifiant Linux* : Type SSH, utilisateur auditscan, mot de passe défini en Partie 2.1 (ou clé SSH si configurée).
 - *Identifiant Windows* : Type Windows / SMB / WMI, compte Administrateur local du serveur.
2. **Création des deux tâches d'audit (*Tasks / Scans*) :**
 - **Scan 1 (Non authentifié)** : Ciblez <IP_LINUX> et <IP_WIN> avec le profil standard *Full and Fast* (sans renseigner d'identifiants).
 - **Scan 2 (Authentifié)** : Ciblez les deux machines en associant les identifiants configurés.
3. Lancez les analyses et suivez la progression dans le tableau de bord.

Partie 4 : Analyse des Résultats et Piège du Rétroportage

Une fois les rapports générés, vous devez trier les alertes pour distinguer les vulnérabilités réelles des faux positifs.

4.1 Priorisation CVSS

1. Consultez la liste des vulnérabilités découvertes sur la machine Linux et la machine Windows.
2. Filtrez les résultats pour isoler les failles de sévérité **Critique** (score CVSS entre 9.0 et 10.0) et **Élevée** (score CVSS entre 7.0 et 8.9).
3. Relevez le vecteur d'attaque (AV:N, AV:A, ou AV:L).

4.2 Investigation d'un Faux Positif de Rétroportage (*Backporting*)

Le scanner externe remonte fréquemment une alerte critique sur un service Linux (ex : OpenSSH, Apache ou Nginx) au seul motif que le numéro de version affiché est inférieur à la version officielle amont (*upstream*).

1. Sur la machine Linux, vérifiez la version exacte du paquet incriminé (exemple avec Apache ou OpenSSH) :

```
dpkg -l | grep -E "apache2|openssh-server"
```
2. Interrogez le journal officiel des correctifs de sécurité appliqués par la distribution :
Exemple pour Apache :

```
apt-get changelog apache2 | head -n 30
```

```
# Exemple pour OpenSSH :  
apt-get changelog openssh-server | head -n 30
```

3. Recherchez dans le journal si la référence CVE remontée par le scanner est mentionnée comme corrigée :

```
apt-get changelog openssh-server | grep -i "CVE-"
```

- **Questions à consigner :**

- La CVE alertée par le scanner a-t-elle été corrigée par le mainteneur de la distribution malgré le numéro de version inchangé ?
- Quelle est la différence fondamentale entre le résultat du scan réseau non authentifié et celui du scan authentifié sur ce point précis ?

4.3 Contrôle des correctifs installés sous Windows

Sur la machine **Windows Server**, inspectez l'état des correctifs de sécurité déployés :

1. Listez les 10 derniers correctifs de sécurité (HotFixes) installés :
Get-HotFix | Sort-Object InstalledOn -Descending | Select-Object -First 10 HotFixID, Description, InstalledOn
2. Vérifiez si une mise à jour cumulative récente est présente sur le système pour corriger les failles SMB ou RDP signalées par le scan.

Partie 5 : Application d'une Première Mesure Corrective Immédiate

Pour valider l'impact direct du durcissement sur le rapport de vulnérabilité, vous allez corriger immédiatement deux anomalies courantes identifiées lors du scan.

5.1 Désactivation d'un service non indispensable (Réduction de surface)

1. **Sur la machine Linux (Service CUPS / Impression) :**
Arrêtez et désactivez définitivement le démon d'impression :
sudo systemctl stop cups cups-browsed
sudo systemctl disable cups cups-browsed
sudo systemctl mask cups
2. **Sur la machine Windows Server (Spouleur d'impression) :**
Arrêtez et verrouillez le service Spouleur :
Stop-Service -Name Spooler -Force
Set-Service -Name Spooler -StartupType Disabled

5.2 Restriction pare-feu ciblée

1. **Sur la machine Linux :** Activez le pare-feu ufw en restreignant l'accès SSH uniquement à la machine d'audit :
sudo ufw default deny incoming
sudo ufw default allow outgoing
sudo ufw allow from <IP_AUDIT> to any port 22 proto tcp
sudo ufw enable
sudo ufw status verbose
2. **Sur la machine Windows :** Restreignez l'écoute RDP uniquement au sous-réseau d'administration :
New-NetFirewallRule -DisplayName "Filtrage RDP Admin" -Direction Inbound -LocalPort 3389 -Protocol TCP -Action Allow -RemoteAddress "<IP_AUDIT>"
3. Depuis la machine d'audit, relancez un scan Nmap rapide sur les ports traités pour vérifier que la surface d'attaque a diminué :
nmap -p 631 <IP_LINUX>
nmap -p 3389 <IP_WIN>

Partie 6 : Livrable – Matrice d'Analyse des Vulnérabilités

Complétez le tableau suivant à l'issue de votre analyse. Ce document servira de référence pour mesurer l'efficacité de vos actions de durcissement tout au long de la semaine :

Équipement	Vulnérabilité / Port détecté	Score CVSS & Sévérité	Vecteur (AV:N / AV:L)	Type (Vrai Positif / Backporting)	Action de remédiation validée
Linux	Ex : Démon d'impression CUPS actif	Ex : 7.5 (High)	AV:N	Vrai Positif	Service stoppé, masqué et désactivé
Linux					
Linux					
Windows	Ex : Spooler d'impression	Ex : 8.8 (High)	AV:N	Vrai Positif	Service désactivé

	<i>n non filtré</i>				<i>via PowerShell</i>
Windows					
Windows					

Critères de validation du TP

- L'ensemble des bannières et ports ouverts a été documenté.
- Le compte auditscan Linux et la liaison WinRM Windows fonctionnent sans erreur d'authentification.
- Les scans authentifiés ont abouti dans l'interface de scan.
- Au moins un cas de faux positif lié au rétroportage a été identifié et justifié via apt-get changelog.
- La fermeture des services superflus a été validée par un contre-scan Nmap.